

能源互联网信息安全风险分析及浅见

0. 引言

笔者近日聆听了耿华老师做的《信息化趋势下的能源互联网技术》讲座，系统地了解了能源互联网的诞生、现状和未来，以及我国建设能源互联网的驱动力和必要性。笔者结合日常工作及研究，写成此文。

1. 背景

1.1. 能源互联网发展

美国社会学家杰里米·里夫金在其著作《第三次工业革命》中认为第三次工业革命将是一场能源革命。可再生能源与互联网的结合，正是这一场革命的重要推动力。随着经济的快速发展，我国已经是世界上最大的能源生产国和消费国，同时也是最大的碳排放国。随着国家经济实力的增强，人民群众的生活改善，环境问题成为我国人民生活中越来越重视的话题。2010年以来，雾霾、饮用水污染、土壤毒化等问题屡屡登上各类媒体的头条，严重地影响了国人的健康和日常生产生活等活动。尽管在不断调整能源结构，我国的能源消费结构仍然是化石能源为主，清洁能源的占比较低。这样的能源消费结构成为了环境问题屡现的主要原因之一。

2015年9月26日，习近平总书记在联合国发展峰会上倡议探讨构建全球能源互联网，推动以清洁和绿色方式满足全球电力需求。中国电力企业联合会在一年以后出台的企业标准 T/CEC 101.1-2016 中，对能源互联网定义如下：以电能为核心，集成冷、热、燃气等能源，综合利用互联网等技术，深度融合能源系统与信息通信系统，协调多能源的生产、传输、分配、存储、转换、消费及交易，具有高效、清洁、低碳、安全特征的开放式能源互联网络。电能替代和清洁替代成为能源互联网的两项关键目标。电能替代是以电能替代冷、热、燃气、燃油等其它能源，目的是降低分布式的排放比例，减少散烧，以电动汽车、电能采暖、电能锅炉等为代表的改变是电能替代的主要体现。清洁替代是以清洁能

源代替化石能源生产电能，包括水、风、阳光等，目的是进一步降低化石燃料在能源结构中的比例，从而减少产生的排放。

1.2. 能源互联网的相关技术

由于我国清洁能源和需求的逆向分布，能源互联网建设对电网运行带来了巨大挑战。特高压输电技术、储能技术以及智能电网技术都亟待进一步发展。这些技术又高度依赖电网信息化、数字化和智能化的程度。目前我国的电网在输变电的自动化发展相对成熟，但是营销和配电网的自动化程度还较低，距离数字化、智能化还有很大差距。

目前，我国的两大电网公司（国家电网和南方电网）都提出了以数字化转型为核心的智能电网建设的战略目标。电力物联网建设成为实现数字化转型的关键要素。随着电力物联网建设的进行，两大电网公司都初步具备了接入海量智能物联终端的能力，为能源互联网的建设、发展打下了良好的基础。

1.3. 能源互联网的安全风险

由于物联网设备的计算能力有限，且具有海量、异构、分散、无人值守、应用场景庞杂、安全防护能力差等特点，如何保护电力物联网络成为一个庞大的安全难题。另一方面，当今世界，以能源基础设施为目标的攻击越来越多。2015年乌克兰电网遭受黑客攻击，导致了部分地区长达6个小时的停电。2016年以色列的电力系统遭受了大规模的网络攻击，导致电力公司不得不下线了大量的计算机设备。2019年委内瑞拉数次全国性的大停电事件也源于黑客攻击，严重影响了民众生活。2020年，美国、欧洲、巴西、印度、日本等国家的电力系统都爆出其多次遭受黑客攻击，对其电力供应产生了不同程度的影响。

因此，我国在规划、建设能源互联网的同时，信息安全建设必须同步进行。

1.4. 本章小节

本章内容简述了我国发展能源互联网的重要意义，同时阐述了智能电网对于能源互联网建设的必要性和紧迫性，最后通过列举近年来的电力系统的安全事件强调了能源互联网的信息安全建设的必要性与紧迫性。

2. 能源互联网的安全分析

2.1. 安全现状

我国的电网企业一直以“安全分区、网络专用、横向隔离、纵向认证”的“十六字方针”作为信息安全的基本指导。“十六字方针”在电网信息化建设中，有效的保障了电网的信息安全。但是，随着能源互联网的建设不断深入，“十六字方针”以边界防护为主的理念，无法适应与高度数字化、智能化，且具有泛在连接，开放共享等特性的能源互联网的现实需求；一定程度上甚至制约了能源互联网的建设与发展。因此，建设能源互联网亟待出现突破“十六字方针”的信息安全理念。

2.2. 安全设计理念的局限性

电力信息网络是工业信息网络在电力系统的具体体现。早期工业信息网络的安全防御体系的设计源自企业信息网络安全的设计理念：采用自上而下的架构设计理念，强调管理级、系统级的安全。这样的理念在传统的企业办公网络中得到了充分的发展和应用，在以边界防御为核心的工业信息网络中（包括电网系统），也取得了不错的效果。随着物联终端接入数量的增加，受到算力、环境、分布等因素的限制的物联终端无法应用源自数据中心的策略和防御手段。为了保障生产业务的连续性，大量物联终端便完全暴露安全防护体系之外；出现了“管而不控”，甚至“不管不控”的现象。这时，终端安全事件一旦发生，管理人员难以及时发现。APT（Advanced Persistent Threat，高级持续威胁）类型的攻击的前期入侵通常能够利用这种疏漏，成功地在物联终端上侵入，并成为下一步攻击的桥头堡。自上而下的设计理念，容易产生云端及数据中心重兵把守，边缘及终端防御缺失的现象，对系统的整体安全带来了巨大的风险。

为了应对自上而下的设计理念的局限性，工业信息网络中诞生了自下而上的安全设计理念。自下而上的理念以单个设备为基础，强调设备个体的安全。通过对设备自身安全能力的增强，实现“细胞级”的自身安全免疫能力。这一设计理念，强化了网络设备的个体安全，在不具备系统级防护能力的在工业信息网络中，取得了不错的效果。但是在具有海量的异构设备，且安全管理要求较高的场景中，以个体为基础的安全策略暴露出难以统一管理的问题；同时，由于安全事件由个体自身的安全能力处置，安全管理者无从知晓这些安全事件，因此自下而上的设计理念通常不具备“识别、保护、检测、响应、恢复”的安全闭环能力。

2.3. 物联网的安全隐患

2.3.1. 云端服务及应用缺陷

由于云端服务所部署的数据中心通常都是“重兵把守”，即使出现缺陷，被直接攻击的可能性也相对较小，而且往往都能够得以迅速修补。攻击者通常会寻找 SQL 注入，跨站脚本等漏洞进行攻击，这类攻击行为往往容易被防火墙、WAF(Web Application Firewall)等边界安全设备发现。但是有一类缺陷是由于服务设计中的逻辑错误导致的，利用这类缺陷的攻击者行为和正常用户无异，往往难于发现。但一旦被黑客掌握，却会带来重大的影响。笔者就曾经向 CNVD 报告了某智慧门禁系统在网络失效后的应急开门功能的逻辑漏洞(CNVD-2019-19059)。能源互联网中业务系统复杂，数据交互节点众多，特别要注意这类逻辑错误。

2.3.2. 网络缺陷

网络缺陷包括物联网系统建设中对于边界的防护缺失或者对于网络设备接入的管控缺失，以及所使用的网络协议的缺陷。由于物联网通常设备数量多，分布广，边界防护很难做到尽善尽美，设备接入管控也会受到物联终端功能简单算力低的影响而不能完全起作用，经常需要物理手段协同防护。而攻击者往往会选择分布较为偏僻的物联终端，绕过物理防护进行渗透。除了有线连接之外，大量的物联终端设备使用无线通信协议，包括 4G、5G、NB-IoT、Wi-Fi、蓝牙、Zigbee、LoRa、红外等都是能源互联网中常见的终端无线通信协议。2016 年就有研究者利用 ZigBee 协议中的漏洞，感染并传播了一个智能灯泡“蠕虫”，能够达到“几分钟内迅速造成一个城市的大面积灾难性破坏”效果。能源互联网的建设中，存在大量无人值守的区域，并安装有大量的智能设备和传感器，如何保护这些设备的安全成为能源互联网的一项重大课题。

2.3.3. 设备缺陷

由于物联网终端结构简单、成本低，能耗、体积和工作环境都有限制，设备厂商为了满足设备功能不得不对系统进行简化，因此，漏洞几乎难以避免。随着针对物联网终端的攻击活动的增多，对物联网终端设备固件实施逆向后进行漏洞分析的技术已经较为普遍，成为攻击者发现物联网终端漏洞的常用手段之一。物联网设备产量大，分布广；设备厂商们在系统层面相互借鉴的模块很多，因此，一个漏洞可能会影响成千上万甚至上百万的

设备：从简单的默认用户名、口令，到静态代码后门、数据明文传输等，没有任何防护的登录入口，或者使用不加密的或者过于简单的加密协议的通讯协议等等，都让攻击者能够更加轻松地“拥有”目标设备。能源互联网中引入了大量的智能终端设备，对终端的保护很难如传统计算机一样集中管理；攻击者更加容易对终端设备进行分析并获取设备缺陷。

2.3.4. 人为因素

除了上述由于技术造成的缺陷之外，人的因素也日渐成为物联网重大的安全隐患。利用社会工程学的非传统网络攻击始终存在。社会工程学已经充分融入到多种网络攻击形式中，包括钓鱼邮件、钓鱼网站、论坛、即时通信工具等都成为其载体。由于企业内部员工通常不注意鉴别真伪，只有在损失发生后才能知晓遭到了攻击。另一方面，大量的物联网智能终端的部署施工都是对安全甚至信息技术不甚了解的普通工程人员。出于部署简单、管理容易等需求，大量的物联网设备存在着弱口令，简化配置，大量以 root 权限运行的服务，以及“千机一密”等问题。此外，由于物联网终端设备和业务数据直接相关，为了避免设备失效造成业务损失，很多终端设备存在着“终生”不升级的现象，导致新暴露的安全问题无法得到修复。因此，非盈利组织 Open Web Application Security Project® (OWASP) 将“缺乏设备管理”列入构建、部署或管理物联网系统时应该规避的十大问题之一。

2.4. 能源互联网的安全需求

发展能源互联网，必须要正视现有体系的缺失和智能物联网及设备的现实状况。需要针对能源互联网“云、管、边、端”的架构，充分考虑能源互联网及其设施的特性以及生产、传输、调度、消费等各方面的需求及现状，提出一种新的设计理念，能够保证“云、管、边、端”中整体与个体安全，同时具备整体安全闭环管理的能力。

2.5. 本章小节

本章简单介绍了我国电网公司目前的安全建设方针，并分析了工业信息网络中常见的安全架构设计的优势与不足，然后列举了物联网系统中常见的安全风险和隐患，以及可能造成的影响。最后提出针对能源互联网“云、管、边、端”的架构，需要一种新的安全设计理念。

3.1. 边缘安全区域自治，云边协同管理安全

The diagram illustrates a cloud-edge collaborative security management architecture. At the top, a cloud icon contains the text "云边协同安全管理" (Cloud-Edge Collaborative Security Management). Below the cloud, three edge nodes are shown, each labeled "安全区域自治" (Security Area Autonomy). The nodes are connected to the cloud via dashed lines. The left node is connected to the cloud via a solid line labeled "可信接入" (Trusted Access). The middle node is connected to the cloud via a solid line labeled "可信接入". The right node is connected to the cloud via a dashed line labeled "可信接入" and a red "X" mark, indicating a security event. The cloud is also connected to the left node via a dashed line labeled "安全策略下发" (Security Policy Distribution) and to the right node via a dashed line labeled "安全事件上报" (Security Event Reporting).

由于边缘区域部署位置通常不具备较强的物理安全防护，且相互连接协议多样，访问请求主体复杂，粗粒度的授权与网络隔离很难为边缘区域各类资源提供有效的安全保护。零信任网络架构（Zero Trust Network Architecture, ZTNA）具备软件定义边界（Software Defined Perimeter, SDP）和网络微隔离（Microsegmentation）的能力。零信任的核心是从不信任，总是验证，只做最小授权（least privilege），并对行为持续监控。这使得 ZTNA 能够适应边缘侧的应用场景，有效的做好安全防护。同时 ZTNA 也可以为边缘侧设备接入云端主站提供可信安全认证和最小化授权的能力，达到云边协同安全管理的目的。

3.2. 研发与采购，关注“供应链安全”

大部分安全问题来自于物联网设备在设计和开发过程中。出于成本考虑多数开发者只考虑功能特性而忽视安全因素。而物联网设备的使用者也只关注产品的性能而忽视安全性。在这样的情况下，一旦暴露安全问题，影响非常严重。在能源互联网的建设过程中，一方面要求设备厂商在设计研发过程中就充分考虑安全，做好代码的安全审计和测试；另一方面，作为使用者在采购过程中，应该做好充分的设备安全性测试与评估，做好“供应链安全”管理。在采购端的安全性测试与评估可以将严重的安全隐患封堵在系统之外，同时也有助于安全系统了解和评估整体系统的安全态势，对暂时不可升级或替代的设备，采用防火墙封堵，实时监控等手段以“虚拟补丁”的方式对隐患进行封堵。

3.3. 安全持续监控与反馈

在零信任架构中，要求系统能够对访问请求动态度量，对访问控制策略动态调整。这需要物联网的拥有者和管理者在实际部署应用后，对整个网络的安全态势持续监控，并具备依据安全态势不断更新和调整访问控制策略的能力：一旦发现异常，需要有能力取消对该访问的授权。由于异常判断依赖威胁情报、以及可能来自其它域的安全事件等信息，必须具备整体视角进行信息收集和分析。在以边缘计算为中心的设计体系下，边缘计算节点、边缘网络安全网关和云端交互安全网关都需要将自身的安全态势上报云端，并随时接收并执行云端下发的安全策略。安全持续监控需要具备威胁情报收集、安全日志收集、自动化的安全分析以及策略下发等主要能力（图 2）。

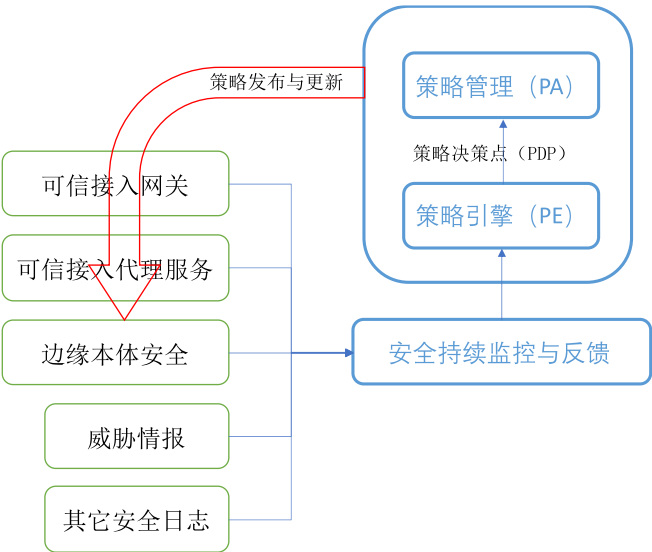


图 2. 安全持续监控与反馈

3.4. 本章小结

本章根据能源互联网的特点，提出了边缘安全区域自治，云边协同管理安全的设计理念，同时提出了安全前置的“供应链安全”和安全持续监控与反馈的需求。

4. 结束语

能源互联网以电能替代和绿色替代为主要目标，是习近平新时代生态文明思量的重要践行。能源互联网的安全运行关系到国计民生，国家安全。作为能源互联网安全的重要一环，能源互联网的信息安全任重道远。本文是笔者结合日常工作和对能源互联网的粗浅理解所作，有很多不足之处。能源互联网的信息安全依赖的要素很多，需要全体参与人员真正关注信息安全，并在建设和运行过程中持续优化和改进安全理念、方法和管理过程。能源互联网信息安全建设，任重道远。